

CWE AI Working Group: Existing Entry Modifications

Meeting Minutes

June 6, 2025

Attendance

Monika Akbar	Martin Hodo	Pieter van Wassenauer
Erick Galinkin	Steve Christey	Caroline Rocha
Lee Szilagyi	Bob Heinemann	Chris Gourley
Kevin Monette	Dave Morse	
Michael Simon	Kyle Norland	

Agenda

- Status Updates
- Detailed Discussion: Getting Examples of “General” CWEs That Affect AI/ML Products

Meeting Notes:

Status Updates

- **Public GitHub Repository:** Steve reminded the team that the content development repository (CDR) on GitHub has been made fully public as part of the CWE 4.17 release in April, and the next release is targeted for August 2025.
- **Tasking and Reminders:** Steve discussed tasking and provided reminders, emphasizing the need to follow through on bringing in new subgroup leaders by the end of June.

Detailed Discussion: Getting Examples of “General” CWEs That Affect AI/ML Products

- **AI Machine Learning Weaknesses:** Steve discussed the goal of identifying weaknesses in AI machine learning products, mentioning that only five CWEs are

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

currently labeled as affecting AI machine learning. The team aims to identify the most common weaknesses in AI machine learning components.

- **General Software CWEs:** Steve noted that AI machine learning software could be subject to any of the 900+ weaknesses currently covered by CWE, and the aim is to identify those most common in AI machine learning components.
 - **Process for Identification:** Steve outlined a basic process for identifying weaknesses, including covering academic research, using CVE data, and creating demonstrative examples.
- **Data-Driven Approach:** Steve proposed a process to identify weaknesses in AI machine learning systems by covering academic research, using CVE data, and creating demonstrative examples. The team collected some papers in the last meeting and will continue to do so.
 - **CVE Data:** Steve suggested using CVE data to identify CWEs that affect AI machine learning products or adjacent products and then making changes to those CWE entries.
 - **Demonstrative Examples:** Steve emphasized creating and defining AI-specific demonstrative examples, which are theoretical code examples showing how weaknesses could be addressed.
- **Data Provenance and Data Poisoning in AI Development:** Lee emphasized the critical role of data provenance in AI, highlighting it as a unique challenge compared to traditional software development. He also underscored the risks of data poisoning, where compromised training datasets could undermine the integrity of AI models. Both issues, he suggested, should be addressed within the scope of CWE.
- **Federated AI Security:** Martin shared insights from a recent security audit on secure federated AI, emphasizing the importance of model integrity during training. He noted that in federated AI, the model itself, rather than the data, could be the primary target for poisoning, highlighting this as a key area for identifying potential weaknesses.
- **AI Exploitation:** Martin and Erick discussed the challenges posed by AI systems exploiting vulnerabilities, whether intentionally or unintentionally. Erick provided examples of AI executing malicious code, stressing the need to address these risks within CWE and CVE frameworks. He suggested that AI exploitation should be a

focus for the new weakness group due to its complex interactions with vulnerabilities.

- **State Preservation:** Steve and Erick highlighted the critical role of state preservation in AI systems, noting that this issue is underrepresented in CWE. Steve shared examples from web browsers and hardware to illustrate the importance of maintaining state integrity, which could similarly impact AI systems.
- **Demonstrative Examples:** Steve emphasized the value of creating demonstrative examples to educate developers about AI system weaknesses. He outlined their structure—introductory text, bad code, explanation of the weakness, and good code or fixes—and acknowledged the labor-intensive nature of this work, while underscoring its educational benefits.
- **Authorization Issues:** Chris raised concerns about authorization in agentic AI, where agents often have higher privileges than users, creating security risks. Erick suggested tagging these issues with CWE-250 (execution with unnecessary privileges) and provided examples of agents with excessive write permissions, leading to unfettered database access that should be restricted.

Next Steps: Steve proposed focusing on serialization, hidden functionality, and authorization issues, and coordinating with Erick to engage the team via email. The next meeting will be rescheduled due to the July 4th holiday.

CVE Quality Working Group: Erick highlighted the growing importance of the CWE AI working group's output for the CVE program, noting its relevance for improving CVE guidance.

Action Items:

- **Subgroup Leadership:** Conclude onboarding of new subgroup leaders by the end of June. (Steve)
- **Academic Research Collection:** Collect additional academic papers that discuss flaws in AI/ML systems. (All)
- **NIST 102 Citations:** Harvest additional citations from the NIST 102 document for relevant papers on model backdooring and data poisoning. (Steve, Lee)